

## บทวิจารณ์ Roleplay OWASP — กลุ่มที่ 11

ผู้วิจารณ์: กลุ่ม 7 สมาชิกคนที่ 3 → กลุ่มที่ต้องฟัง =  $((7 + 3) \% 11) + 1 = \text{กลุ่ม 11}$  หัวข้อ: SiamPay Tech ร่าง Security Guidelines กลาง หลัง pentest พบ IDOR ระดับ High ใน API ดูประวัติธุรกรรม

### ตารางให้คะแนน

| รหัส<br>นักศึกษา | ชื่อเล่น / บทบาท                   | ความลึกทาง<br>เทคนิค (10) | Communication<br>(10) | ความพร้อมและ<br>ความจริง<br>(10) | รวม<br>(30) |
|------------------|------------------------------------|---------------------------|-----------------------|----------------------------------|-------------|
| 6610110188       | กฤต / CTO – Head<br>of Engineering | 8                         | 9                     | 9                                | 26          |
| 6610110635       | พีตัส / Security<br>Lead (AppSec)  | 9                         | 8                     | 8                                | 25          |

### เหตุผลประกอบ

#### 6610110188 (กฤต — รับบท CTO ผังแรงกดดันด้านเวลาและต้นทุน)

- **ความลึกทางเทคนิค 8/10:** แม้เล่นบทผู้บริหาร แต่หลายครั้งเป็นฝ่ายเสนอภัยคุกคามเอง เช่น ตอนไล่ STRIDE ของ flow "โอนเงินหาเพื่อน" ได้ยกเรื่อง "ขโมย session token หรือทำ SIM swap เพื่อรับ OTP" "ส่งค่าติดลบเพื่อกลับทิศการโอน ต้อง validate ที่ server" และ "ระบบตอบต่างกันระหว่าง "ไม่พบผู้ใช้" กับ "พบ: สมชาย ใจดี" ทำให้ enumerate ได้" ในช่วง IDOR อธิบายเหตุผลที่ "ตอบ 404 ไม่ใช่ 403" และเสนอ middleware กลาง ให้ repository layer บังคับ scope ด้วย owner และตั้งชื่อ `admin_get_any()` ให้ review ง่าย ส่วนเรื่อง PIN ก็เสนอ migrate แบบ rehash ตอน login ครั้งถัดไป หักคะแนนเพราะยังมีบางช่วงที่ทำหน้าที่ถามนำ เช่น "เปลี่ยน id เป็น UUID จบไหม" แล้วให้อีกฝ่ายอธิบาย
- **Communication 9/10:** เปิดประชุมได้ชัดด้วย "สามอย่าง" (ธุรกิจโตเร็ว ช่องโหว่ขยายผลห่าเท่า และข้อมูลอยู่ใต้ PDPA) วาง ground rules สามข้อ และสรุปปิดท้ายทุกช่วง เช่น checkpoint หกข้อตอนครบชั่วโมงแรก และการทวนสรุปช่วง Crypto ทำให้คนดูตามทันว่าตกลงอะไรกันไปแล้ว
- **ความพร้อมและความสมจริง 9/10:** เล่นบท CTO ได้สมจริง คือคัดค้านด้วยเหตุผลทางธุรกิจ เช่น "ถ้าทุก feature ต้องมี workshop ผมรับไม่ได้" และ "ถ้า build ล้มเพราะช่องโหว่ที่ยังไม่มี patch... ผมรับไม่ได้" แล้วต่อรองจนได้ข้อสรุปที่ทำได้จริง เช่น แบ่ง MFA เป็นสองเฟส และจัดลำดับ SCA ก่อน image signing ช่วง ad-lib ยอมรับว่า "ทีมผมเขียนเอง ผมเป็นคนอนุมัติ requirement" ทำให้ตัวละครมีมิติ ปิดด้วยตาราง Action Items 15 ข้อที่มี owner และกำหนดเสร็จ

#### 6610110635 (พีตัส — รับบท Security Lead ผังความเสี่ยง)

- **ความลึกทางเทคนิค 9/10:** ครอบคลุมกว้างและลงรายละเอียดถูกต้อง ได้แก่ STRIDE พร้อม trust boundary, การแยก Authentication กับ Authorization จากโค้ด `get_transaction`, หลักสามข้อ (Deny by default, ตรวจสอบที่ server, object-level authorization) พร้อม automated test ใน CI, การยืนยันตัวตนแบบแบ่งระดับแทน SMS OTP, Argon2id/bcrypt, AES-256-GCM และ KMS/HSM, SCA/SBOM (CycloneDX/SPDX)/SAST/DAST, SSRF ผ่าน webhook ไปยัง 169.254.169.254 พร้อมการป้องกัน DNS rebinding และ tabletop ที่อ้าง PDPA 72 ชั่วโมง ไม่ให้เต็มเพราะบอกไว้ว่าจะ "ไล่ให้ครบสิบหมวด" แต่หมวด A10 (Mishandling of Exceptional Conditions ใน OWASP 2025) ถูกแตะเพียงเรื่อง "ปิด stack trace" ไม่ได้ลงลึก
- **Communication 8/10:** มีจุดเด่นที่อธิบาย IDOR ให้เข้าใจง่าย ("ถ้าแฮกเกอร์รู้ว่าเปลี่ยนเลข ID... ดึงข้อมูลคนอื่นได้") และใช้อุปมา "ล็อกประตูแล้วแขวนกุญแจไว้ข้างๆ" แต่หลายช่วงพูดเป็นรายการยาวต่อเนื่อง (ข้อเสนอหัวข้อเรื่อง CI/CD, ลีชข้อเรื่อง logging) ซึ่งฟังทางเสียงแล้วจำได้ยาก ควรเขียนบนไวท์บอร์ดประกอบหรือแบ่งพูดเป็นช่วงสั้นลง
- **ความพร้อมและความสมจริง 8/10:** เตรียมรับข้อโต้แย้งไว้ล่วงหน้า เช่น "ผมคิดเรื่องนี้ไว้แล้วครับ เตรียมกลไก exception..." และยอมประนีประนอมแบบ risk-based แต่ไม่ยอมทุกเรื่อง (ยื่นให้ secret scanning "เปิดทันทีในสัปดาห์นี้") การสลับมาเป็นผู้ยิง inject สามรอบ (23:10, 00:30, 09:00 น.) ทำให้ช่วง Incident Response สมจริงมาก หักคะแนนเพราะบทส่วนใหญ่ยังเป็นการบรรยายฝ่ายเดียว จึงดูเหมือนสอนมากกว่าประชุมในบางช่วง

**ภาพรวม:** เลือกสถานการณ์ที่สมจริง (fintech + PDPA + pentest จริง) และเชื่อม OWASP แต่ละหมวดเข้ากับระบบของบริษัทเองได้ดี การปะทะกันระหว่าง "ความเร็ว" กับ "ความเสี่ยง" ทำให้ข้อสรุปออกมาเป็นสิ่งที่ปฏิบัติได้ ไม่ใช่แค่ทฤษฎี